

BUILDING A TRUSTED SECURITY GRAPH RAG

A practical design guide for Security Operations

How to use this guide - page 1 of 2 Start here if RAG, Graph RAG, vector databases, or security knowledge graphs are new to you.

What this guide is trying to solve

A security team can have a strong language model and still get a weak answer. The reason is often not the model. The problem is the context around the model: the wrong data was retrieved, the source was stale, the internal environment was not checked, or an earlier AI-generated statement was treated as fact.

This guide focuses on that context layer. It explains what should be indexed, what should be queried live, what should stay temporary, and what can become durable knowledge after human validation.

Five ideas to keep in mind

Step	Plain-language meaning
SOURCE	Choose trusted external sources and internal systems of record.
STRUCTURE	Use the retrieval method that fits the data. Not everything belongs in one vector database.
CORRELATE	Connect vulnerability, behavior, identity, asset, exposure, and change context.
TRUST	Every important claim should point back to a source.
MAINTAIN	Refresh, version, deduplicate, expire, and delete stale knowledge.

Key design rule Static or durable knowledge is usually indexed. Dynamic environment state is usually queried live. AI analysis stays temporary unless it is validated.

You do not need to build every component in this guide on day one. The recommended approach is to start with a small set of trusted sources, prove that retrieval works, and only then add more data or more model capability.

How the pieces fit together

Think of the design as four information layers that meet at investigation time.

Reference architecture: durable knowledge and live state meet in a context-and-correlation layer. AI analysis remains separate from validated history.

The left side contains external trusted knowledge: MITRE ATT&CK, CISA KEV, CVE/NVD, NIST guidance, trusted vendor threat intelligence, and approved detection content. This information changes, but it usually changes more slowly and can be indexed with version information.

The right side contains live internal state: ServiceNow/CMDB, AD or Entra, SIEM/EDR, UEBA, asset exposure, change records, and other current operational data. This state can change every minute. It is usually safer to query it live or near-live instead of copying it into a long-lived RAG store.

The context-and-correlation layer resolves identities and joins the two worlds. For example, a CVE from NVD becomes more meaningful when the CMDB confirms that the affected product is installed on an internet-facing production asset.

The model then receives a small, source-backed context package. It can summarize, compare, explain, and propose next steps. Its analysis is useful, but it is still analysis. A human-validated outcome is what can later become durable internal knowledge.

Example in one sentence HOST-17 is internet-facing, runs Product-X, Product-X is affected by CVE-X, CVE-X is in CISA KEV, the host shows PowerShell activity that maps to ATT&CK T1059.001, and the user is privileged. The model should receive these facts with source references, not guess them from memory.

A. Plain-language glossary

Use this page when a term in the guide is unfamiliar.

Term	Meaning
RAG	Retrieval-Augmented Generation. The system retrieves relevant information and gives it to the language model as context before the model answers.
Vector database	A store that supports semantic similarity search. It is useful when the analyst asks for information with similar meaning, even if the exact words differ.
Graph / knowledge graph	A structure that stores entities and relationships, such as HOST-17 RUNS Product-X or Campaign-X USES T1059.001.
Graph RAG	A retrieval pattern that uses graph relationships, often together with normal text/vector retrieval, to bring connected facts into the model context.
CMDB	Configuration Management Database. A system such as ServiceNow CMDB can hold asset, owner, application, criticality, lifecycle, and relationship data.
UEBA	User and Entity Behavior Analytics. UEBA produces behavioral signals such as unusual logins, first-time access, or anomalous activity. A signal is not the same as a confirmed incident.
Provenance	The record of where a fact came from: source system, record ID, version, timestamp, URL, and validation state.
Durable knowledge	Information that is approved to persist and be reused, such as validated incidents, approved playbooks, or trusted external security knowledge.
Live state	Information that can change quickly, such as current group membership, current asset exposure, current alerts, or a current change window.
AI hypothesis	A model-generated interpretation or recommendation. It can help an analyst, but it should not be treated as a trusted fact until validated.

Common pitfall Do not use “RAG” as a catch-all name for every data source. Keep indexed knowledge, live queries, graph relationships, and temporary AI reasoning separate.

1. Why a Security RAG is different

Security retrieval is not only a document-search problem. The system must understand source trust, time, identity, exposure, and operational context.

In a normal business RAG, a user may ask a question about a policy, a handbook, or a set of documents. In a SOC, the analyst may ask whether a specific host, user, alert, process, CVE, or threat report matters right now. That changes the design problem.

Security information also has different lifetimes. MITRE ATT&CK technique definitions are versioned knowledge. A CISA KEV entry can change when a vulnerability is added or updated. A privileged group membership can change immediately. A UEBA anomaly score is a point-in-time signal. These should not be stored and refreshed in the same way.

A useful Security RAG therefore needs more than semantic similarity. It needs exact identifiers, structured fields, graph relationships, source provenance, access control, and a plan for freshness and deletion.

Rule of thumb Use exact lookup for exact facts, graph traversal for relationships, vector search for narrative meaning, and live queries for volatile state. One retrieval method should not be forced to do every job.

2. Four information layers

Keeping these layers separate prevents AI interpretation from quietly becoming trusted evidence.

The four-layer operating model used throughout this guide.

Layer 1 - external trusted knowledge

This is knowledge that comes from established external sources. Examples include MITRE ATT&CK, CISA KEV, CVE/NVD, NIST guidance, trusted vendor CTI, and approved public detection content. It is useful because it describes known techniques, vulnerabilities, campaigns, guidance, and detection patterns outside your organization.

Layer 2 - live internal state

This is what is true inside your environment now. Examples include ServiceNow/CMDB asset records, AD/Entra identity and privilege, SIEM/EDR events, UEBA signals, change records, exposure state, and current control coverage. This data often changes too quickly to trust a stale copy.

Layer 3 - live AI reasoning

This includes summaries, hypotheses, recommended next steps, generated ATT&CK mappings, and risk interpretations. It can be helpful during the investigation, but it is model output. It should remain clearly labeled and temporary unless a validation process promotes it.

Layer 4 - validated historical knowledge

This is reusable internal history: analyst-confirmed incidents, approved outcomes, lessons learned, approved playbooks, reviewed detections, and validated mappings. It is valuable because it carries organizational context and a known validation state.

Keep the layers separate A future investigation must be able to distinguish an external fact, a live signal, an AI hypothesis, and a confirmed outcome. If those categories blur together, old interpretation can return later as if it were evidence.

3. External sources and internal sources

External knowledge explains what something can mean. Internal state explains what it means in your environment.

External source	What it contributes
MITRE ATT&CK	Techniques, sub-techniques, software, groups, campaigns, relationships, and versioned identifiers.
CVE / NVD	Vulnerability records, descriptions, product/vendor context, severity data, references, and modified dates.
CISA KEV	A structured list of vulnerabilities known to have been exploited in the wild. Useful as one prioritization input.
NIST	Security and incident-response guidance. Mostly narrative, so vector retrieval with metadata can be useful.
Vendor CTI	Narrative reports, actors, malware, campaigns, TTPs, CVEs, IOCs, and publisher-specific context.
Detection content	Sigma or other approved detection logic that can map behavior to techniques or investigation steps.

Internal source	What it contributes
ServiceNow / CMDB	Asset identity, owner, application, business criticality, product/version, lifecycle, dependencies, and change context.
AD / Entra	Identity, role/group membership, authentication, privilege, device, and sign-in context.
SIEM / EDR	Current investigation telemetry, events, process activity, alerts, and security-native query results.
UEBA	Behavioral signals such as unusual login, new access pattern, or anomalous entity activity. Treat as signal, not verdict.
Exposure / attack surface	Internet-facing state, network zone, cloud/VPC context, open services, and control coverage.
Validated incidents	Confirmed outcomes and evidence lineage that can be reused after quality review.

Why this matters A high CVSS score does not automatically create the highest operational priority. An isolated lab asset with strong segmentation and no known exploitation may be less urgent than an internet-facing production gateway with a lower CVSS score when that vulnerability is in KEV and active exploitation is reported.

4. Use the retrieval method that matches the data

Graph RAG is useful, but it is not the answer for every source.

A common RAG design starts by converting everything into chunks and embeddings. That is simple, but it is not a good default for security. Security data often has exact identifiers and strong structure. If the analyst asks about CVE-2026-12345, the system should not depend on semantic similarity to find the record.

The practical design is hybrid. Use several retrieval methods behind one context builder. The analyst does not need to care which method was used; the system does.

Different source types benefit from different retrieval methods.

Data	Preferred retrieval	Why
ATT&CK relationships	Graph traversal + exact ID	Techniques, software, groups, campaigns, and relationships are structured and relational.
CVE / NVD	Exact/structured lookup + vector for prose	Use exact CVE IDs and structured product data; use vector search for advisory text and related narrative.
CISA KEV	Exact/structured lookup	Membership and dates are structured facts.
Vendor threat reports	Vector + entity/relationship extraction	Narrative matters, but actors, techniques, malware, and CVEs can also become graph nodes.
NIST guidance	Vector + metadata filters	The useful content is mostly narrative guidance.
CMDB / ServiceNow	Live structured query	Ownership, lifecycle, criticality, and exposure can change.
AD / Entra	Live structured query	Privilege and identity state are time-sensitive.
SIEM / EDR	Live query / native query language	Do not embed millions of raw events by default.
UEBA	Live API/query	Keep signal, score, timestamp, and source. Do not promote anomaly to fact.
Validated incidents	Vector + graph + metadata	These are durable internal history after review.

Rule of thumb Index durable knowledge, query volatile state, and correlate the two at investigation time.

5. Asset context: severity is not operational risk

The same CVE or behavior can mean something very different depending on where the asset sits and what the asset does.

Asset context should be a first-class input to retrieval. A host name and owner are not enough. For investigation and prioritization, the system often needs exposure, environment, business criticality, identity dependency, sensitive data, installed product/version, control coverage, and recent change state.

Useful asset attributes

- Asset ID, business owner, application, environment, and business criticality.
- Network location: internal, DMZ, OT zone, cloud VPC/subnet, or segmented network.
- External exposure: internet-facing, private-only, VPN-only, or partner-accessible.
- Physical or cloud location only when it changes the security decision.
- Data sensitivity, identity dependency, privileged access, and security controls such as EDR, MFA, or segmentation.
- Installed product/version, patch state, approved change window, and lifecycle state.

Illustrative comparison: a higher CVSS score does not automatically mean higher immediate operational risk.

Avoid this Do not ask the LLM to invent a risk score from CVSS, KEV, exposure, and criticality. Use an organization-defined prioritization method, or present the factors to the analyst without pretending they form a precise score.

6. Establish relationships that have security meaning

A graph is valuable only when its edges help answer a real investigation question.

Graph RAG is attractive because security data is connected. A threat actor can use a technique. A CVE can affect a product. A host can run that product. A user can administer the host. A change record can apply to the asset. A validated incident can confirm that a detection was meaningful.

The negative side is graph sprawl. It is easy to connect everything to everything and create a dense graph that is difficult to trust, expensive to maintain, and hard to explain. The guide recommends creating an edge only when there is a defensible source and a clear operational use.

Graph rule Keep provenance on every cross-source relationship. If an edge cannot be traced to a source, it will be difficult to defend during an investigation or review.

External to external relationships

Source A	Source B	Useful relationship
Vendor CTI	MITRE ATT&CK	Threat actor/campaign USES technique; malware PERFORMS technique.
Vendor CTI	CVE / NVD	Actor/campaign EXPLOITS or DISCUSSES CVE.
Vendor CTI	CISA KEV	Link through the CVE when the report discusses a KEV-listed vulnerability.
Vendor CTI	Detection content	Report TTP/IOC INFORMS detection logic.
CVE / NVD	CISA KEV	CVE IS LISTED IN KEV.
CVE / NVD	Detection content	Detection IDENTIFIES exploitation behavior for CVE.
MITRE ATT&CK	Detection content	Detection DETECTS technique/sub-technique.
NIST	Approved playbook/policy	Guidance SUPPORTS a response/control step. Avoid inventing ATT&CK mappings.

7. Connect external knowledge to the internal environment

This is where public security knowledge becomes organization-specific context.

External sources alone cannot tell you whether a vulnerability, technique, campaign, or indicator matters to your company. Internal systems alone cannot tell you whether observed activity matches a known technique or active exploitation pattern. The correlation layer joins them.

External	Internal	Relationship
MITRE ATT&CK	SIEM / EDR telemetry	Observed behavior MAPS TO technique.
MITRE ATT&CK	Internal detection	Rule DETECTS technique.
MITRE ATT&CK	Validated incident	Incident CONTAINED / CONFIRMED technique.
CVE / NVD	CMDB asset/product	Asset RUNS product AFFECTED BY CVE.
CISA KEV	CMDB asset/product	Asset HAS vulnerability that IS LISTED IN KEV.
Vendor CTI	SIEM / EDR	IOC/TTP MATCHES observed telemetry.
Vendor CTI	CMDB asset	Threat report TARGETS product/technology/sector relevant to asset.
Vendor CTI	Validated incident	Incident RESEMBLES / WAS ATTRIBUTED TO campaign only if validated.
NIST	Internal playbook	Playbook IS BASED ON / ALIGNS WITH guidance.
Detection content	SIEM / EDR rule	External/approved rule IS IMPLEMENTED AS local detection.

Example NVD says Product-X is affected by CVE-X. CMDB says HOST-17 runs Product-X. CISA KEV says CVE-X is known exploited. The graph can now answer a useful question: “Which internet-facing production assets run a product affected by a KEV-listed vulnerability?”

8. Connect internal systems without turning context into proof

Internal relationships explain ownership, access, change, exposure, and business impact.

Internal A	Internal B	Relationship
CMDB asset	AD / Entra identity	User OWNS / USES / ADMINISTERS asset.
CMDB asset	Change record	Change APPLIES TO asset.
CMDB asset	SIEM / EDR event	Event OCCURRED ON asset.
CMDB asset	UEBA signal	Behavioral signal IS ASSOCIATED WITH asset.
AD / Entra identity	SIEM / EDR event	User GENERATED / AUTHENTICATED IN event.
AD / Entra identity	UEBA signal	User HAS behavioral anomaly.
AD / Entra identity	Privileged group	User IS MEMBER OF group/role.
Change record	SIEM / EDR event	Approved change MAY EXPLAIN activity.
Validated incident	Asset / identity	Incident AFFECTED asset / INVOLVED identity.
Validated incident	Detection	Alert WAS VALIDATED IN incident.
Validated incident	Playbook	Playbook WAS USED / UPDATED from lessons learned.
Playbook	Asset type / detection	Playbook APPLIES TO asset class / RESPONDS TO detection.

Watch out “May explain” is different from “explains.” A change ticket is context until the analyst confirms that it actually accounts for the observed activity.

9. Worked SOC example: build context around HOST-17

The purpose of the graph is not to create a verdict. It is to assemble a traceable investigation package.

Illustrative relationship graph for HOST-17. Each edge should retain source, timestamp, and validation state.

Assume a detection fires because PowerShell activity is observed on HOST-17. A weak approach is to send the process line to a model and ask whether it is malicious. A stronger approach first builds context from the systems that already know something about the host, user, vulnerability, technique, and threat landscape.

Possible retrieval package

- ServiceNow/CMDB: HOST-17 runs Product-X; asset criticality is high; exposure is internet-facing.
- NVD/CVE: Product-X is affected by CVE-X.
- CISA KEV: CVE-X is listed as known exploited.
- SIEM/EDR: PowerShell activity was observed on HOST-17.
- MITRE ATT&CK: the observed behavior maps to T1059.001 when the evidence supports the mapping.
- AD/Entra: Alice accessed HOST-17 and currently holds a privileged role.
- Vendor CTI: Campaign-X has reported use of the same technique or vulnerability.

What the model should do Summarize the connected evidence, clearly separate facts from inference, state what is still unknown, and cite every material source. Do not convert correlation into attribution without supporting evidence.

10. Worked example: context can outweigh raw severity

This example is intentionally simple. It shows why a vulnerability score should not be the only input to SOC prioritization.

Illustrative case comparison. The factors are inputs; they are not an automatically generated AI score.

Case A has a higher CVSS score, but the vulnerable asset is an internal test server with no internet exposure, low business criticality, no KEV listing, and strong segmentation. Case B has a lower CVSS score, but the affected system is an internet-facing production gateway, the vulnerability is in KEV, active exploitation is reported, and the system sits on a privileged identity path.

Case B is not automatically the higher priority in every organization, but it illustrates why operational risk is contextual. Retrieve the factors that matter to the organization, then apply a defined policy or present those factors clearly to the analyst.

Watch out Do not let the model create a precise numerical risk score unless the organization has defined the scoring policy and the data inputs are reliable.

11. UEBA and live AI analysis

Behavioral analytics and model reasoning can help the investigation without becoming permanent truth.

UEBA tools such as Exabeam can surface unusual behavior: a first privileged login, a new access path, a deviation from normal timing, or an entity risk score. These are valuable signals because they tell the analyst where to look. They are not proof of compromise.

AI analysis should be treated the same way. A model can say “possible credential compromise” or recommend a lateral-movement check. That is an interpretation generated at investigation time. The system should label it as a hypothesis and keep it separate from trusted knowledge.

Step	Example	Status
1. UEBA signal	Exabeam/UEBA flags a first-time privileged login and unusual PowerShell activity.	Live analytical signal
2. Live context	AD/Entra confirms role membership; CMDB identifies the asset; SIEM/EDR supplies events.	Current-state facts
3. AI analysis	“Possible credential compromise; investigate lateral movement.”	Hypothesis
4. Analyst outcome	Analyst confirms approved admin activity during a change window.	Validated outcome
5. Durable record	Store the confirmed case outcome and evidence lineage. Do not store the original AI hypothesis as fact.	Reusable history

Keep the distinction clear A UEBA score is not a malicious verdict, and an AI hypothesis is not a fact. A validated outcome may become durable knowledge after review.

12. Build trust by showing the source behind every important claim

Trust should come from evidence that an analyst can inspect, not from confident wording.

A source-backed answer is easier for an analyst to review. If the model says HOST-17 is internet-facing, the analyst should be able to see the CMDB or exposure record that supports that statement. If the model says a vulnerability is known exploited, the answer should point to CISA KEV.

Illustrative claim-level provenance. The source is part of the answer contract.

Claim	Required source fields
HOST-17 is internet-facing.	CMDB/exposure service; asset ID; retrieved_at; source record ID.
Product-X is affected by CVE-X.	NVD/CVE; CVE ID; product/version match; source modified date.
CVE-X is known exploited.	CISA KEV; CVE ID; date added; retrieved_at.
Behavior maps to T1059.001.	MITRE ATT&CK; technique ID; ATT&CK version; supporting evidence.
Campaign-X uses this technique.	Vendor CTI; publisher; report title/date; original reference.
Alice is privileged.	AD/Entra; role/group; retrieved_at.

Trust rule Do not ask the analyst to trust the model. Make the supporting evidence easy to inspect.

13. Security RAG hygiene

Retrieval quality depends on what you remove as much as what you add.

RAG hygiene is the routine work that keeps retrieval useful over time. Without it, the knowledge base can accumulate duplicate reports, old IOCs, retired assets, superseded playbooks, stale relationships, and model-generated summaries that later look like evidence.

RAG hygiene belongs in normal operations. It should not be postponed until the knowledge base becomes difficult to trust.

Practice	What good looks like
Provenance	Every node, chunk, and relationship keeps its source.
Canonical IDs	Normalize ATT&CK IDs, CVE IDs, asset IDs, user IDs, and product names.
Deduplication	Prevent the same underlying report or fact from appearing as multiple independent confirmations.
Versioning	Keep ATT&CK/NIST/playbook versions and source modified dates.
Freshness	Track retrieved_at, valid_from, valid_to, and last_verified where practical.
Expiry / deletion	Remove stale CTI, retired assets, superseded playbooks, obsolete relationships, and expired temporary context.
AI-output quarantine	AI summaries and hypotheses stay outside the trusted store until validated.
Access control	Do not let RAG bypass identity, case, HR, legal, or need-to-know restrictions.
Data minimization	Ingest only the fields needed for the security task.
Retrieval tests	Regularly test known questions and verify that the right evidence is returned.
Re-indexing	Update graph/vector indexes after meaningful source changes.
Audit trail	Record what changed, when, why, and by which process or person.

Hygiene rule Deletion is part of retrieval quality. A larger knowledge base is not automatically a better knowledge base.

14. Maintenance: keep the knowledge current

Use source-specific maintenance. Do not apply one refresh schedule to every source.

Different sources age at different speeds. ATT&CK changes when new versions are released. KEV and NVD can change daily. Vendor CTI may contain short-lived IOCs and more durable TTP information. CMDB and identity state can change at any time. Playbooks should change through an approval process.

For dynamic systems such as ServiceNow, AD/Entra, SIEM/EDR, and UEBA, the safest default is to query live or near-live when an investigation needs the information. If the system caches results, the cache must have an explicit lifetime.

Source	Example starting cadence	Maintenance action
MITRE ATT&CK	On release/change trigger	Re-ingest changed objects; preserve version; remove/relabel revoked or deprecated content.
CISA KEV	Daily or event-driven	Refresh structured catalog; preserve dateAdded and changes.
CVE / NVD	Daily/API-driven where needed	Update modified CVEs; re-link products/assets after material changes.
Vendor CTI	At ingestion + review window	Record report date; age out short-lived IOCs; retain durable TTP context when still useful.
NIST / approved guidance	On publication or internal review	Version documents and superseded guidance.
ServiceNow / CMDB	Query live or near-live	Avoid stale copies for ownership, lifecycle, criticality, and exposure.
AD / Entra	Query live	Privileges and sign-in state are time-sensitive.
SIEM / EDR / UEBA	Query live	Investigation evidence and scores are time-bound.
Playbooks	On approval/change	Retire superseded versions; preserve audit history.
Validated incidents	After closure/quality review	Promote only confirmed facts and outcomes.

Maintenance loop Ingest -> verify -> normalize -> index -> monitor -> refresh -> expire/delete -> re-index -> test retrieval. These cadences are design examples, not universal requirements.

15. Where this design can fail

Graph RAG adds capability, but it also adds engineering and governance cost.

A connected knowledge layer creates additional failure modes. Some come from bad data, some from access control, and some from model reasoning. The design should make those limitations visible rather than hide them behind a polished answer.

Failure mode	What goes wrong	Control
Entity-resolution errors	“ACME VPN” in CTI is linked to the wrong product or internal asset.	Use canonical IDs, product/version matching, and validation.
Stale joins	The graph says Alice administers HOST-17 after her role changed.	Query dynamic identity/asset state live; expire cached edges.
Over-correlation	Several weak signals are presented as if they prove compromise.	Preserve signal type and avoid automatic verdicts.
Permission leakage	The model retrieves data the analyst should not see.	Enforce authorization before retrieval, not after generation.
Graph complexity	Too many nodes/edges make retrieval slower and harder to explain.	Start with a narrow ontology and add edges only when useful.
Bad extraction	LLM entity extraction from CTI creates false relationships.	Require source trace, confidence, and review for durable graph writes.
Licensing / redistribution	A vendor feed restricts storage or redistribution.	Respect feed terms and store only permitted content or metadata.
False precision	A generated risk score looks scientific but has no policy basis.	Use defined organizational scoring or show factors separately.
Operational cost	Sync, indexing, graph maintenance, and testing take time.	Prove value with a small use case before expanding.

Where Graph RAG helps Use graph retrieval when relationships materially improve retrieval, prioritization, or explanation. A graph adds cost and complexity, so it should earn its place.

16. Pilot blueprint

Start small enough that every relationship can be inspected by hand.

The first pilot should prove retrieval quality before it tries to prove model capability. If the context layer returns the wrong entities, relationships, or source references, model benchmarking will not tell you much.

Phase 1 - build a small trusted knowledge layer

- MITRE ATT&CK: techniques, groups, software, campaigns, and relationships.
- CISA KEV + NVD/CVE: vulnerability facts and known-exploitation status.
- Two or three vendor CTI reports: extract actors, malware, TTPs, CVEs, and report provenance.
- Synthetic internal data: 20-50 assets, a small identity set, exposure fields, 5-10 changes, a few playbooks, and a few validated cases.

Phase 2 - prove retrieval before model quality

- Write 30-50 known-answer investigation questions.
- Measure whether the correct entities, edges, and source references are retrieved.
- Test stale data, conflicting identifiers, duplicate reports, and access restrictions.
- Do not allow AI write-back to trusted knowledge during the pilot.

Phase 3 - test model efficiency

- Compare a small open-source/on-prem model with and without trusted retrieval.
- Compare vector-only retrieval with graph + structured + live retrieval.
- Measure answer correctness, unsupported claims, citation accuracy, latency, and cost.
- Treat “better retrieval compensates for model size” as a hypothesis until the data supports it.

Pilot rule First prove that the system retrieves the right context. Then test whether a smaller model can use that context effectively.

17. Take-home build checklist

Use this page before you add any new source to the system.

Check	Question
SOURCE	Is the source authoritative, an internal system of record, or clearly labeled as an analytical signal?
PURPOSE	What investigation question does this source help answer?
FRESHNESS	How quickly can it change? Should it be indexed or queried live?
IDENTITY	Does it have canonical IDs for CVE, ATT&CK, asset, user, product, or campaign?
RELATIONSHIP	Which specific edges are useful? Which edges would be speculative?
PROVENANCE	Can every retrieved fact point to the original source or record?
ACCESS	Who is allowed to retrieve it?
RETENTION	When should it expire, be deleted, or be replaced?
AI BOUNDARY	Can AI-generated content write back? Default answer: no.
VALIDATION	What must happen before an AI hypothesis becomes durable knowledge?
TESTING	What known-answer questions prove retrieval is working?
OWNER	Who owns source health, mappings, and maintenance?

Architecture in one line Index durable trusted knowledge, query current internal state, correlate at investigation time, cite the evidence, and promote only validated outcomes.

18. Reference sources and notes

These are the source families used throughout this guide. Product names are examples, not endorsements.

[1] MITRE ATT&CK - ATT&CK Data & Tools

Machine-readable STIX 2.0/2.1 data, official TAXII access, and versioned ATT&CK datasets.

<https://attack.mitre.org/resources/attack-data-and-tools/>

[2] CISA - Known Exploited Vulnerabilities Catalog

CISA describes KEV as the authoritative source of vulnerabilities known to have been exploited in the wild and recommends it as an input to vulnerability prioritization.

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

[3] NVD - Vulnerabilities API / developer resources

NVD-enriched CVE data and modified vulnerability records.

<https://nvd.nist.gov/developers/vulnerabilities>

[4] CVE Program

Canonical CVE identifiers and CVE Records.

<https://www.cve.org/>

[5] NIST SP 800-61 Rev. 3

Incident-response recommendations aligned to CSF 2.0.

<https://csrc.nist.gov/pubs/sp/800/61/r3/final>

[6] ServiceNow CMDB

Configuration items, relationships, lifecycle information, and data-quality capabilities.

<https://www.servicenow.com/products/servicenow-platform/configuration-management-database.html>

[7] Microsoft Entra sign-in logs

Identity activity including who, how, what, device/location, and sign-in context.

<https://learn.microsoft.com/en-us/entra/identity/monitoring-health/concept-sign-ins>

[8] Exabeam - UEBA resources

Example commercial source for behavioral analytics and anomaly/risk signals.

<https://www.exabeam.com/resources/ebooks/the-ultimate-guide-to-behavioral-analytics/>

[9] FIRST EPSS

Optional vulnerability-prioritization signal for probability of exploitation in the next 30 days; not a complete organizational risk score.

<https://www.first.org/epss/>

[10] SANS - AI-Assisted. Human-Led. Trusted Investigations.

Reference for human accountability, validation, and evidentiary integrity in AI-assisted DFIR/IR workflows.

<https://www.sans.org/go/ai-assisted-human-led-trusted-investigations>

Implementation note Refresh schedules in this guide are starting points, not universal requirements. Adapt them to the organization's risk, data sources, operating model, and retention requirements.